PENSE-BÊTE · MÉTHODES ET GOUVERNANCE

Gestion de la sûreté PME/ETI

03-580 DRSD - Guide pratique de gestion de la sûreté des PME et ETI de la BITD — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La sûreté traite de la malveillance et des risques intentionnels tandis que la sécurité concerne les risques accidentels ou naturels.
2. La défense en profondeur s'organise par des barrières successives de la périphérie vers la volumétrie avec des mesures humaines, organisationnelles et techniques.
3. L'équation de sûreté impose que le temps de freinage soit strictement supérieur au temps cumulé de détection, de traitement de l'alarme et d'intervention.

Enjeux et objet du guide

Notion	À retenir
PME/ETI ciblées	Maillons essentiels de la sous-traitance, vulnérables, détenant des **savoir-faire critiques** pour la souveraineté nationale face aux **actions hybrides**.
Sûreté compétitivité	Obligation de sécurité (**Art. L4121-1** du code du travail) ; critère discriminant des **services achats** ; devient un **business partner**.
Organisation guide	Partie **théorique** (fondamentaux) et **didactique** (méthode `PDCA`). Distingue **mesures pour commencer** et **mesures pour aller plus loin**.

Principes et gouvernance de la sûreté

Notion	À retenir
Les grands principes	Intégration à la **stratégie** pour protéger **personnel**, **patrimoine matériel** et **immatériel**. Fondée sur la **défense en profondeur**, l'**équation de sûreté** et la norme `ISO 31000` (risque de **malveillance**).
La gouvernance de la sûreté	Engagement de la **direction** (vision, rôles, ressources, culture). Couvre **personnel**, **physique** et **informations**. Le **responsable sûreté** doit avoir un accès direct à la direction et peut recevoir une **délégation de pouvoir**.

Éléments clés de la gouvernance

Élément	À retenir
Politique générale de sûreté	Gouvernance, objectifs **mesurables**, conformité, documentation, sensibilisation, revue de direction.
Plan de sûreté	Protège les valeurs, démontre la maîtrise des risques, structure la réponse : **gouvernance**, **évaluation des risques**, **plan de traitement**, **amélioration continue**.
Revue de direction	Idéalement **annuelle** : adéquation stratégie/enjeux, efficacité, ressources, priorités ; **procès-verbal**.

Système de management de la sûreté

Notion	À retenir
Management du risque	Passage à l'acte : **motivation**, **facilité d'action**, **impunité** ; stratégie : **dissuader**, **alerter**, **bloquer/freiner**, **réagir/intervenir**, **limiter/supprimer**.
Analyse et traitement	Analyse : contexte, identification des **valeurs** (guide **DRSD/DPID 2023**).
Surveillance et veille	Indicateurs : **suivi d'activité** (rondes, incidents, badges), **performance** (% sensibilisation, temps levée de doute), **ROI** (coûts évités, contrats gagnés).
Continuité et crise	PCA/PRA : définir **périmètre**, **élaborer**, **processus d'activation**, **maintien en condition opérationnelle**.

Les trois domaines de la sûreté

Notion	À retenir
Sûreté du personnel	Vérifier **éligibilité** et **aptitude**. Procédures : consignes, arrivées/départs, visiteurs, sensibilisation, personnel temporaire. International : conseils **MEAE**, inscription **Ariane**. Jurisprudence **Abidjan** (7/12/2011).
Sûreté physique	Appliquer `security by default` et `security by design`. Socle : **protection mécanique** + **contrôle d'accès** (possession, connaissance, identité). Détection d'intrusion : alarme, alerte, **levée de doute**, intervention.
Sécurité des informations	Garantir la **DCIT** du cycle de vie. Catégorisation des données critiques. Hygiène numérique (**ANSSI**) : hameçonnage, gestionnaire de mots de passe, **double authentification**, signalement d'incidents.

Référentiels et normes de sûreté

Domaine	Référentiel / Norme	Précisions
Contrôle d'accès	**APSAD D83**	Référence CNPP
Détection d'intrusion	**APSAD R81**	Référence CNPP
Vidéosurveillance	**APSAD R82**	Référence CNPP
Télésurveillance	**APSAD R31**	Référence CNPP
Vidéoprotection	**Autorisation préfectorale** (5 ans)	Voie publique ou abords ; 3 niveaux : surveillance, reconnaissance, identification
Sécurité numérique	**ANSSI**	Recommandations hygiène numérique
Agents de sécurité	**CNAPS**	Réglementation des agents privés

Cycle PDCA de la sûreté

Notion	À retenir
Planifier	Identifier **responsable sûreté**, **valeurs**, **4 ou 5 grands risques**. S'auto-évaluer (**13 exigences** du référentiel **DGA**). Rédiger au moins une **note de sûreté** (ex: **règlement intérieur**).
Déployer	Formaliser **responsable sûreté** et adjoint. Sensibiliser personnel (min. **tous les 3 ans**). Détection intrusion : **volumétrique double technologie**, alarme sonore, alerte **télésurveillance**, levée de doute. Chiffrement des infos sensibles.
Vérifier et ajuster	Tester mesures, évaluer écarts, analyser **KPI** et **ROI**, audits, exercices, **RETEX**. Ajuster : points sûreté (ex: **trimestriels**), réparer, sensibiliser, mettre à jour procédures.

Méthode flash

15
actions pour commencer

19
actions pour aller plus loin

Pièges et confusions

- ⚠ Confondre la sûreté (malveillance) et la sécurité (risques accidentels).
- ⚠ Oublier que le temps de freinage doit être strictement supérieur au cumul des temps de détection, de traitement et d'intervention.
- ⚠ Négliger le contrôle d'accès alors que la grande majorité des intrusions passent par les accès.
- ⚠ Ignorer que la vidéoprotection de l'espace public nécessite une autorisation préfectorale de 5 ans.
- ⚠ Sous-estimer l'importance de la confidentialité des mesures de sûreté pour leur efficacité.

Sigles et définitions

BITD Base industrielle et technologique de défense.

Sûreté Prévention et lutte contre la malveillance (risques humains et intentionnels).

Sécurité Prévention et lutte contre les risques accidentels, naturels et technologiques.

SMS Système de management de la sûreté, outil opérationnel et méthodologique.

DCIT Disponibilité, confidentialité, intégrité et traçabilité des informations.

PDCA Démarche d'amélioration continue : Plan, Do, Check, Act.

RETEX Retour d'expérience, analyse a posteriori d'un événement.

Auto-test

1. Qu'est-ce que la malveillance ?
2. Quels sont les trois espaces de la défense en profondeur ?
3. Que signifie l'acronyme HOT ?
4. Quels sont les trois types d'indicateurs mentionnés ?
5. Qu'est-ce que la levée de doute ?

Réponses : **1.** Un risque d'origine humaine et intentionnel visant une personne ou le patrimoine. · **2.** La périphérie, la périmétrie et la volumétrie. · **3.** Mesures Humaines, Organisationnelles et Techniques. · **4.** Suivi d'activité, KPI et ROI. · **5.** La vérification qu'une alarme correspond à une intrusion réelle.

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.